



ZAP by
Checkmarx

OWASP ZAP API Cuidarte+ : 4444

Sitio: <http://localhost:4444>

Generado a mar, 8 sept 2026 00:15:39

ZAP Versión: 2.17.0

ZAP by [Checkmarx](#)

Sumario de Alertas

Nivel de riesgo	Número de Alertas
Alto	0
Medio	2
Bajo	2
Informativo	0

Insights

Level	Razón	Site	Descripción	Statistic
Bajo	Advertencia		ZAP errors logged - see the zap. log file for details	3
Bajo	Advertencia		ZAP warnings logged - see the zap. log file for details	5
Información	Informativo		Percentage of network failures	7 %
Información	Informativo	http://localhost:3333	Percentage of responses with status code 2xx	60 %
Información	Informativo	http://localhost:3333	Percentage of responses with status code 3xx	34 %
Información	Informativo	http://localhost:3333	Percentage of responses with status code 4xx	4 %

Información	Informativo	http://localhost:3333	Percentage of endpoints with content type application/javascript	16 %
Información	Informativo	http://localhost:3333	Percentage of endpoints with content type image/svg+xml	16 %
Información	Informativo	http://localhost:3333	Percentage of endpoints with content type text/css	16 %
Información	Informativo	http://localhost:3333	Percentage of endpoints with content type text/html	50 %
Información	Informativo	http://localhost:3333	Percentage of endpoints with method GET	100 %
Información	Informativo	http://localhost:3333	Count of total endpoints	6
Información	Informativo	http://localhost:4444	Percentage of responses with status code 2xx	44 %
Información	Informativo	http://localhost:4444	Percentage of responses with status code 4xx	55 %
Información	Informativo	http://localhost:4444	Percentage of endpoints with content type application/json	33 %
Información	Informativo	http://localhost:4444	Percentage of endpoints with content type text/html	66 %
Información	Informativo	http://localhost:4444	Percentage of endpoints with method GET	100 %

Información	Informativo	http://localhost:4444	Count of total endpoints	3
-------------	-------------	-----------------------	--------------------------	---

Alertas

Nombre	Nivel de riesgo	Número de Instancias
CSP: Failure to Define Directive with No Fallback	Medio	2
Configuración Incorrecta Cross-Domain	Medio	4
El servidor divulga información mediante un campo(s) de encabezado de respuesta HTTP ""X-Powered-By""	Bajo	4
Falta encabezado X-Content-Type-Options	Bajo	Systemic

Detalles de la Alerta

Medio	CSP: Failure to Define Directive with No Fallback
Descripción	The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.
URL	http://localhost:4444/robots.txt
Nombre del Nodo	http://localhost:4444/robots.txt
Método	GET
Ataque	
Evidencia	default-src 'none'
Otra información	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
URL	http://localhost:4444/sitemap.xml
Nombre del Nodo	http://localhost:4444/sitemap.xml
Método	GET
Ataque	
Evidencia	default-src 'none'
Otra información	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
Instancia	2
Solución	Asegúrese de que su servidor web, servidor de aplicación, balanceador de carga, etc. está configurado apropiadamente para establecer la cabecera de Política de Seguridad de Contenido.
Referencia	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medio	Configuración Incorrecta Cross-Domain
Descripción	La carga de datos del navegador web puede ser posible, debido a una mala configuración de Cross Origin Resource Sharing (CORS) en el servidor web.
URL	http://localhost:4444
Nombre del Nodo	http://localhost:4444
Método	GET
Ataque	
Evidencia	Access-Control-Allow-Origin: *
Otra información	La configuración incorrecta de CORS en el servidor web permite solicitudes de lectura entre dominios de terceros arbitrarios, utilizando API no autenticadas en este dominio. Sin embargo, las implementaciones de los navegadores web no permiten que terceros arbitrarios lean la respuesta de las API autenticadas. Esto reduce un poco el riesgo. Esta configuración errónea podría ser utilizada por un atacante para acceder a datos que están disponibles de forma no autenticada, pero que utilizan alguna otra forma de seguridad, como la lista blanca de direcciones IP.
URL	http://localhost:4444/
Nombre del Nodo	http://localhost:4444/
Método	GET
Ataque	
Evidencia	Access-Control-Allow-Origin: *
Otra información	La configuración incorrecta de CORS en el servidor web permite solicitudes de lectura entre dominios de terceros arbitrarios, utilizando API no autenticadas en este dominio. Sin embargo, las implementaciones de los navegadores web no permiten que terceros arbitrarios lean la respuesta de las API autenticadas. Esto reduce un poco el riesgo. Esta configuración errónea podría ser utilizada por un atacante para acceder a datos que están disponibles de forma no autenticada, pero que utilizan alguna otra forma de seguridad, como la lista blanca de direcciones IP.
URL	http://localhost:4444/robots.txt
Nombre del Nodo	http://localhost:4444/robots.txt
Método	GET
Ataque	
Evidencia	Access-Control-Allow-Origin: *
Otra información	La configuración incorrecta de CORS en el servidor web permite solicitudes de lectura entre dominios de terceros arbitrarios, utilizando API no autenticadas en este dominio. Sin embargo, las implementaciones de los navegadores web no permiten que terceros arbitrarios lean la respuesta de las API autenticadas. Esto reduce un poco el riesgo. Esta configuración errónea podría ser utilizada por un atacante para acceder a datos que están disponibles de forma no autenticada, pero que utilizan alguna otra forma de seguridad, como la lista blanca de direcciones IP.
URL	http://localhost:4444/sitemap.xml
Nombre del Nodo	http://localhost:4444/sitemap.xml
Método	GET
Ataque	
Evidencia	Access-Control-Allow-Origin: *
	La configuración incorrecta de CORS en el servidor web permite solicitudes de lectura entre dominios de terceros arbitrarios, utilizando API no autenticadas en este dominio. Sin embargo, las implementaciones de los navegadores web no permiten que terceros

Otra información	arbitrarios lean la respuesta de las API autenticadas. Esto reduce un poco el riesgo. Esta configuración errónea podría ser utilizada por un atacante para acceder a datos que están disponibles de forma no autenticada, pero que utilizan alguna otra forma de seguridad, como la lista blanca de direcciones IP.
Instancia	4
Solución	Asegúrese de que los datos confidenciales no estén disponibles de forma no autenticada (por ejemplo, mediante listas blancas de direcciones IP). Configure el encabezado HTTP "Access-Control-Allow-Origin" a un conjunto más restrictivo de dominios, o elimine todos los encabezados CORS por completo, para permitir que el navegador web aplique la Política del Mismo Origen (SOP) de una manera más restrictiva.
Referencia	https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy
CWE Id	264
WASC Id	14
Plugin Id	10098

Bajo	El servidor divulga información mediante un campo(s) de encabezado de respuesta HTTP ""X-Powered-By""
Descripción	El servidor de la web/aplicación está divulgando información mediante uno o más encabezados de respuesta HTTP ""X-Powered-By"". El acceso a tal información podría facilitarle a los atacantes la identificación de otros marcos/componentes de los que su aplicación web depende y las vulnerabilidades a las que pueden estar sujetos tales componentes.
URL	http://localhost:4444
Nombre del Nodo	http://localhost:4444
Método	GET
Ataque	
Evidencia	X-Powered-By: Express
Otra información	
URL	http://localhost:4444/
Nombre del Nodo	http://localhost:4444/
Método	GET
Ataque	
Evidencia	X-Powered-By: Express
Otra información	
URL	http://localhost:4444/robots.txt
Nombre del Nodo	http://localhost:4444/robots.txt
Método	GET
Ataque	
Evidencia	X-Powered-By: Express
Otra información	
URL	http://localhost:4444/sitemap.xml

Nombre del Nodo	http://localhost:4444/sitemap.xml
Método	GET
Ataque	
Evidencia	X-Powered-By: Express
Otra información	
Instancia	4
Solución	Asegúrese de que su servidor web, servidor de aplicaciones, balanceador de carga, etc. está configurado para suprimir las cabeceras "X-Powered-By".
Referencia	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10037

Bajo	Falta encabezado X-Content-Type-Options
Descripción	La cabecera Anti-MIME-Sniffing X-Content-Type-Options no se ha establecido en 'nosniff'. Esto permite que las versiones anteriores de Internet Explorer y Chrome realicen MIME-sniffing en el cuerpo de la respuesta, lo que puede provocar que el cuerpo de la respuesta se interprete y se muestre como un tipo de contenido distinto del tipo de contenido declarado. Las versiones actuales (principios de 2014) y heredadas de Firefox utilizarán el tipo de contenido declarado (si se establece uno), en lugar de realizar MIME-sniffing.
URL	http://localhost:4444
Nombre del Nodo	http://localhost:4444
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:4444/
Nombre del Nodo	http://localhost:4444/
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
Instancia	Systemic

Solución	Asegúrese de que la aplicación/servidor web establece el encabezado Content-Type adecuadamente, y que establece el encabezado X-Content-Type-Options a 'nosniff' para todas las páginas web. Si es posible, asegúrese de que el usuario final utiliza un navegador web moderno y compatible con los estándares que no realiza MIME-sniffing en absoluto, o que puede ser dirigido por la aplicación web/servidor web para que no realice MIME-sniffing.
Referencia	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021